Editors: Richard Ford, rford@se.fit.edu | Deborah A. Frincke, debfrincke@gmail.com

The Promises and Challenges of Continuous Monitoring and Risk Scoring

Alexander Kott and Curtis Arnold | US Army Research Laboratory

From mobile devices to cloud computing, government technology officials have high hopes for the benefits of continuous monitoring and risk scoring (CMRS). They argue that CMRS will be far more agile, responsive, and perhaps less expensive than such alternatives as periodic (annual) reporting and certification. Indeed, the benefits could be great, but so are the challenges of implementing a successful CMRS system.

Coming to Terms

Authoritative definitions related to CMRS come from National Institute of Standards and Technology (NIST) publication SP 800-137,[1] which describes Information Security Continuous Monitoring as "maintaining ongoing awareness of information security, vulnerabilities, and threats to support organizational risk management decisions," and the Defense Information Systems Agency (DISA), which defines CMRS as "visibility of cyber risks [that] demonstrates the ability to use DOD Enterprise security tools and content," and continuous monitoring as "the ongoing observation, assessment, analysis, and diagnosis of an organization's cybersecurity posture, hygiene, and operational readiness" (www.disa.mil/Services/Information-Assurance/SCM/CM-Definition).

For the purposes of this brief article, we focus on the two most salient aspects of CMRS: continuous data collection through automated feeds and analysis of that data to assess and score risks. The typical data collected for continuous monitoring purposes include network traffic information as well as host information from host-based agents—vulnerability information and patch status about hosts on the network, scan results from tools such as Nessus, TCP netflow data, DNS trees, and so on. These diverse types of information must be collected with appropriate speed, translated from multiple formats, correlated, fused, organized, and stored for further processing. The "risk scoring" step includes flagging especially egregious vulnerabilities and exposures, or computing metrics that provide an overall characterization of the network's risk level. Currently used risk metrics are often simple sums or counts of vulnerabilities and missing patches. More on this shortly.

Early Beginnings

The first and best-known example of a successful CMRS system is iPost, developed and deployed by the US Department of State in 2009. iPost went on to win the NSA's Frank B. Rowlett Award and became the basis for follow-on efforts to extend and apply similar approaches in other organizations.

Although it isn't yet easy to point to major CMRS successes other than iPost, the concept of a CMRS has attracted strong interest and commitment, particularly from the US government. In 2010, the Office of Management and Budget directed federal agencies to use automated continuous monitoring and risk models.[2] The Department of Defense recently released a document on its mobile device strategy that specifies continuous monitoring as part of the device management service,[3] immediately followed by a document on cloud computing strategy that similarly gives a major role to CMRS.[4] In particular, cloud providers hosting DoD data offsite will have to integrate their continuous monitoring and response capabilities with US Cyber Command's systems for protecting DoD information.

Authorized licensed use limited to: INSTITUTE OF ENGINEERING & MANAGEMENT TRUST. Downloaded on April 24,2026 at 14:32:33 UTC from IEEE Xplore. Restrictions apply.

 1540-7993/13/$31.00 © 2013 IEEE

Such strategic documents can have far-reaching ramifications. Numerous corporations interested in providing or supporting mobile device services and cloud computing services to the US government will rush to implement a CMRS capability. Other national governments, for example, the one in Australia, might be exploring similar approaches.[5] Related practices will eventually spill over into commercial, nongovernment sectors.

A Growing Need

What caused this burst of interest in CMRS? Perhaps the most dominant forcing function is financial: the Federal Information Security Management Act of 2002 (FISMA) imposes on government agencies rigorous, annual reporting requirements. DoD programs like the DoD Information Assurance Certification and Accreditation Process (DIACAP) impose a three-year cycle of certification and accreditation requirements that are exceedingly expensive, in terms of both being labor intensive and a major management burden. In addition, two to three years are such astronomically long times in our age of daily technological changes that the accreditation process is hardly effective in terms of enhanced security. To have any degree of effectiveness, such an accreditation should be performed far more often, but who can afford this when even a three-year cycle is prohibitively costly? Enter CMRS. It promises a potential reduction in costs along with dramatic improvements in timeliness and reliability of risk awareness and remedies.

The reduction of costs and risks is comprised of several key components. Importantly, CMRS is expected to reduce costs associated with regulatory compliance and accreditation. Automated data feeds—many of which are already available within enterprise systems and can be used for CMRS purposes—along with semiautomated risk assessments can reduce costs associated with conventional data gathering for accreditation. Management burden is likely to diminish accordingly. Because CMRS provides near continuous visibility of assets and costly and dangerous situations such as rogue devices, misconfigurations and patch failures are recognized and corrected rapidly and with less need for multiple, costly security controls. If a security control diminishes in effectiveness, continuous monitoring is likely to highlight the trend and encourage timely changes.

Particularly promising are the benefits of automated risk quantification—that is, assigning risk scores or other numerical measures to the network as a whole, its subsets, and even individual assets. This opens doors to true risk management decision making, which could potentially be highly rigorous and insightful. Employees at multiple levels—from senior leaders to system administrators—will be aware of continually updated risk distribution over the network components and will use this awareness to prioritize resource application to the most effective remedial actions. Risk quantification can also contribute to rapid automated or semiautomated implementation of remediation plans.

Challenges on the Horizon

Great benefits, however, come with major challenges, and CMRS is no exception. These challenges primarily fall into two categories: information aggregation and risk quantification. The first centers on the problem of integrating and fusing highly heterogeneous information. Continuous monitoring implies consistent, largely centralized collection and processing of information—a difficult objective to achieve in any large-scale, geographically distributed, and functionally diverse enterprise system. CMRS system developers must deal with broad heterogeneity of technologies on the network, including that of the technologies that obtain and provide data feeds to the CMRS data collection mechanisms. These data—very diverse in their nature and content—arrive in widely differing formats, often with uncertain and imprecise semantics, with timeliness, availability and completeness varying between the technologies and across different segments of the network. Departments and agencies have different missions, constraints, business processes, and corresponding differences in systems. Hopes for increasing uniformity and consistent standardization are unlikely to be fulfilled; system heterogeneity will continue to increase.

Data integration benefits from availability and continuing development of standards such as the Security Content Automation Program (SCAP), which standardizes identification and description of security issues and includes the Common Vulnerabilities and Exposures (CVE) dictionary, the National Vulnerability Database (NVD), which relates vulnerabilities and software, and the Common Vulnerability Scoring System (CVSS), which provides a severity score for each vulnerability. SCAP has been a major enabler of CMRS. However, even if data integration is achieved successfully, a larger challenge still looms—that of information fusion, a technically profound problem that has been a subject of extensive research for decades, and will likely remain such for many years to come.

Part of dealing with data and system heterogeneity is to establish an overarching strategy and architecture for integration of these widely different data flows.[6] This requires an agreement among a potentially

Authorized licensed use limited to: INSTITUTE OF ENGINEERING & MANAGEMENT TRUST. Downloaded on April 24,2026 at 14:32:33 UTC from IEEE Xplore. Restrictions apply.

large number of stakeholders, which in turn requires lengthy diplomacy while the high pace of technology threatens to make any major architecture outdated by the time an agreement on an all-encompassing architecture is reached. An alternative approach might be a relatively loose confederation of local solutions. The cybersecurity community has recognized the importance of architectural approaches in CMRS, and several related efforts are underway. For example, the Department of Homeland Security collaborates with several other departments of the federal government in developing and extending the Continuous Asset Evaluation, Situational Awareness, and Risk Scoring (CAESARS) reference architecture for continuous monitoring (www.dhs.gov/continuous-asset-evaluation-situational-awareness-and-risk-scoring-reference-architecture-report).

The second group of challenges is the lack of rigorous approaches to computing risk. Existing risk-scoring algorithms remain limited to ad hoc heuristics such as simple sums of vulnerability scores or counts of things like missing patches, open ports, and so on. Multiple specialists have pointed out the weaknesses and potentially misleading nature of such metrics.[7,8] For example, individual vulnerability scores are dangerously reliant on subjective, human, qualitative input and can be potentially inaccurate or expensive to obtain. Furthermore, the total number of vulnerabilities could matter far less than how vulnerabilities are distributed over hosts or over time. Similarly, neither topology of the network nor the roles and dynamics of interhost interactions are accounted for by simple sums of vulnerabilities or counts of missing patches.

Numerous others factors strongly impact the risks to a network and yet are unaccounted for by existing metrics—nonlinear interactions between vulnerabilities, the importance of assessing risks with respect to adversary intent and capabilities, the impossibility of considering risks without an estimate of how a compromise might affect the organization's mission, and the need to account for the presence or absence of appropriate network defense mechanisms. Regarding the particularly serious risks from advanced persistent threats, it's doubtful that any risk scoring based on known vulnerabilities is applicable. In general, there's a pronounced lack of rigorous theory or models of how various factors might combine into quantitative characterization of true risks. Initial efforts attempt to formulate scientifically rigorous methods of calculating risks and should be given strong consideration in practical CMRS implementations.[9]

CMRS's great benefits come with great challenges, which fall primarily into two categories: information aggregation and risk quantification.

Also lacking is rigorous empirical validation of risk metrics, whether they're heuristic or theoretically grounded. Little documented empirical evidence suggests that currently used risk scores exhibit correlation with actual risks experienced by systems to which the scores are applied. Although it might seem intuitively compelling that a heuristic metric such as a count of major vulnerabilities is a reasonable reflection of true risks, the intuition is no substitute for rigorous evidence and might be misleading, at least in some cases. CMRS implementers and operators shouldn't overlook an opportunity to collect empirical data that would remedy this shortage of evidence.

Although the challenges of CMRS are real and significant, they shouldn't deter organizations from implementing a CMRS solution. Benefits of CMRS are undoubtedly great, and even a partial solution will bring a significant fraction of the benefits. As the collective experience with CMRS solutions grows, the science and technology community will produce new solutions to some of the technical challenges we mentioned here, while others could turn out to be less critical in practice than they appear now. ■

References

1. K. Dempsey et al., "Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations," NIST Special Publication 800-137, Nat'l Inst. Standards and Tech., Sept. 2011.
2. Executive Office of the President, Office of Management and Budget, Memorandum M-10-15, 21 Apr. 2010; www.whitehouse.gov/sites/default/files/omb/assets/memoranda_2010/m10-15.pdf.
3. Dept. of Defense Chief Information Office, "Mobile Device Strategy," May 2012; www.defense.gov/news/dodmobilitystrategy.pdf
4. Dept. of Defense Chief Information Office, "Cloud Computing Strategy," July 2012; www.defense.com/news/dodcloudcomputingstrategy.pdf.
5. Defense Signals Directorate, "Strategies to Mitigate Targeted Cyber Intrusions," Oct. 2012; www.dsd.gov.au/infosec/top-mitigations/top35mitigationstrategies-list.htm.
6. W. Jackson, "Is Continuous Security Monitoring Worth the Payoff?," Defense Systems, 4 Apr. 2012; http://defensesystems.com/

Authorized licensed use limited to: INSTITUTE OF ENGINEERING & MANAGEMENT TRUST. Downloaded on April 24,2026 at 14:32:33 UTC from IEEE Xplore. Restrictions apply.

Articles/2012/04/04/FOSE-Continuousmonitoring.aspx?Page=1.
7. W. Jensen, "Directions in Security Metrics Research," NISTIR 7564, Nat'l Inst. Standards and Tech., Apr. 2009.
8. N. Bartol et al., "Measuring Cyber Security and Information Assurance: A State of the Art Report," Defense Technical Information Center, May 2009.
9. R.P. Lippman et al., "Continuous Security Metrics for Prevalent Network Threats: Introduction and First Four Metrics," tech. report ESC-TR-2010-090, MIT, May 2012.

Alexander Kott is chief of the Network Science Division of the US Army Research Laboratory, where he leads R&D efforts that include network assurance, cybersecurity, and risk assessment. He received a PhD from the University of Pittsburgh. Contact him at Alexander.Kott1@us.army.mil.

Curtis Arnold is chief of the Sustaining Base Network Assurance Branch at the US Army Research Laboratory. He received an MS in information technology from Johns Hopkins University and is pursuing his doctorate in information assurance from Capitol College. Contact him at Curtis.B.Arnold@us.army.mil.

cn *Selected CS articles and columns are also available for free at http://ComputingNow.computer.org.*

Call for Papers

Health IT Security and Privacy

for *IEEE Security & Privacy's* November/December 2013 issue

Final submissions due: 1 March 2013

The November/December 2013 special issue of *IEEE Security & Privacy* will take an unprecedented look at how to protect privacy and strengthen security of patients' health information in an electronic and interconnected health care system. The goal of this special issue is to provide a forum for researchers, practitioners, and policy-makers to delve deeply into these issues, exchange results, discuss experiences, and outline opinions.

We welcome case studies, experience reports, practices, research results, and standards reports. Our readers are eager to hear about industry experiences, especially resulting from empirical studies that teach us how past successes and failures should inform the next generation.

Questions? Contact the guest editors: Kelly Caine (Clemson University, caine@clemson.edu) and Michael Lesk (Rutgers University, lesk@acm.org)

To view the full CFP, visit

www.computer.org/security/cfp

Authorized licensed use limited to: INSTITUTE OF ENGINEERING & MANAGEMENT TRUST. Downloaded on April 24,2026 at 14:32:33 UTC from IEEE Xplore. Restrictions apply.